



HECVAT vs 1EdTech TrustEd Apps: map rubric overlaps and coverage gaps across security, privacy, and accessibility in a comparison matrix

Computer

EdTech compliance mapping: build an interactive crosswalk between HECVAT 4 and 1EdTech TrustEd Apps rubrics for procurement teams

Computer

Turn this scorecard into a vendor intake workflow

Draft email request for HECVAT and TrustEd Apps

Add an AI governance rubric for HECVAT and TrustEd

HECVAT and 1EdTech TrustEd Apps should be treated as complementary procurement instruments: HECVAT provides the deeper vendor-risk questionnaire, while TrustEd Apps provides education-specific transparency, privacy, security, accessibility, AI, and interoperability evidence. A strong Semester intake workflow should request both, normalize their answers into a single evidence register, and identify gaps before contract approval.

1EdTech's Generative AI Data Rubric is a supplier self-assessment that emphasizes disclosure when generative AI is used, user choice/opt-in or opt-out, policy disclosure, data sources, and whether AI is internal or third-party. [¹⁶⁹²][¹⁶⁹³]

HECVAT and TrustEd crosswalk

Control area	HECVAT 4 emphasis	1EdTech TrustEd Apps emphasis	Overlap	Coverage gap to manage	Semester evidence
Company governance	Organization, policy, legal, risk, workforce governance	Public company/policy information and accountability	High	HECVAT is usually deeper on formal organizational controls	Governance charter, RACI, policy register, risk register
Security program	Security management, policies, workforce training, risk	Baseline supplier security procedures	High	1EdTech is a baseline rubric; HECVAT often requests more implementation detail	Security policy set, training, assessment schedule
Cloud infrastructure	Hosting, network, infrastructure, configuration, operations	Systems management and third-party hosting disclosure	High	HECVAT generally probes technical depth more thoroughly	Cloud architecture, IaC, CSPM, network controls
Identity/access	Authentication, authorization, MFA, privileged access, reviews	Authentication/account-management practices	High	HECVAT typically expects stronger operational evidence	IAM architecture, MFA evidence, access-review reports
Secure SDLC	Application security, testing, change/release control	How supplier builds/maintains software	High	HECVAT may require deeper SAST/DAST/pentest/patch detail	CI/CD controls, PR evidence, threat models, scans

Control area	HECVAT 4 emphasis	1EdTech TrustEd Apps emphasis	Overlap	Coverage gap to manage	Semester evidence
Encryption/key management	Encryption, key management, secrets, storage/transit	Data protection/security practices	High	Need implementation configuration, not statement only	KMS/secrets architecture, TLS/encryption configurations
Logging/monitoring	Monitoring, logging, detection, investigation	Security practice/process disclosures	Medium-high	Define log retention, alert testing, privileged audit coverage	SIEM design, sample alert, investigation record
Incident response	IR plan, notification, testing, post-incident process	Security incident procedures	High	HECVAT tends to ask for timelines/process evidence	IR plan, tabletop results, corrective-action tracker
Business continuity	Backup, DR, RTO/RPO, availability	Service/operations security practices	Medium	TrustEd generally does not replace detailed DR review	Restore test, DR plan, RTO/RPO evidence
Privacy/data inventory	Data types, processing, privacy program, contractual controls	Collected data, collection method, ownership, purpose	High	HECVAT often needs detailed technical/process evidence	Data inventory, data-flow diagram, DPA
Sharing and subprocessors	Third-party risk, data transfers, contractual controls	Hosting, sharing, disclosure, policy transparency	High	Need regional/residency, onward-transfer, exit-plan evidence	Subprocessor list, vendor assessments, DPAs
Retention/deletion	Lifecycle, disposal, backup, legal obligations	Retention, deletion rights, ownership/control	High	Specify operational backup deletion and legal hold behavior	Schedule, deletion tests, hold runbook
FERPA/education records	Privacy/legal/contractual safeguards	Education-data ownership and transparency	Medium-high	FERPA exception analysis and consent workflow need institution-specific legal review	Consent/disclosure log, school-official terms, access matrix
Accessibility	IT accessibility, conformance, alternatives	Accessibility rubric: documentation, procurement communication, conformance, alternatives/accommodations	High	HECVAT may capture procurement requirement; TrustEd is more directly edtech-focused	ACR/VPAT, manual tests, issue tracker
Interoperability	Integration/API security and data transfer	LTI, OneRoster, QTI and certification/conformance ecosystem	Medium	HECVAT does not establish educational standards conformance	LTI/OneRoster/QTI test results, integration docs
Community/social features	Privacy, content, incident/safety controls	Social-interaction disclosure and data practices	Medium-high	Add moderation, safeguarding, appeal, and crisis-boundary evidence	Community policy, moderation runbooks, case audit
AI transparency	AI/privacy/vendor/change controls in HECVAT 4	AI disclosure, purpose, data sources, provider/internal-vs-third-party, user preference	High	Add technical model safety, evaluation, misuse response, and high-impact decision controls	AI policy, model inventory, provider assessment, user disclosures
AI data use/training	AI data handling, vendor controls, privacy/security	Policy disclosure, user choices, data-source and provider transparency	High	Need technically enforced no-training default and deletion/retention evidence	Provider terms, DLP/config evidence, AI data-flow diagram

Control area	HECVAT 4 emphasis	1EdTech TrustEd Apps emphasis	Overlap	Coverage gap to manage	Semester evidence
AI safety and misuse	AI risk governance, security, testing, operational controls	Emerging rubric work; broad supplier transparency	Medium	Add NIST AI RMF/AI 800-1 tests, red teaming, incident/kill-switch evidence	Risk register, eval reports, red-team results, AI incident runbook
Grade/assessment integrity	Data integrity, availability, app controls	Learner-data responsibility/AI disclosure	Medium	Add educational validity, rubric provenance, human grading, appeal	Grade ledger, rubric versioning, audit trail, appeal policy

Coverage rule

HECVAT answers:

“How does the vendor manage security, privacy, accessibility, infrastructure, operations, AI, and third-party risk?”

TrustEd Apps answers:

“Is this education technology transparent, responsible, interoperable, privacy-aware, accessible, and understandable to institutions and learners?”

NIST AI RMF / AI 800-1 answers:

“Has the organization identified, evaluated, controlled, and monitored AI-system and misuse risks throughout the lifecycle?”

No one framework replaces the others.

Vendor intake workflow

1. Intake request

Requester submits:

Vendor name

Product/module

Business purpose

Institutional sponsor

Data categories

Student/faculty/staff audience

Integration requirements

AI features/providers

Accessibility impact

Contract value and term

Target go-live date

The intake system auto-classifies:

Low:

No student data, no SSO, no integration, no AI, no sensitive workflow.

Moderate:

Authentication, limited directory data, low-risk instructional/service use.

High:

Education-record data, SSO/SCIM/LTI/SIS integration, grade data, student-generated content, AI, moderation, community features.

Critical:
Financial data, health/basic-needs/referral data, proctoring,
high-stakes assessment, minors, broad production data export,
agentic/external actions, or consequential decision support.

2. Request evidence

Risk tier	Required evidence
Low	Privacy policy, terms, accessibility statement, basic security questionnaire
Moderate	Above plus data map, subprocessor list, DPA, security overview, integration scope, AI disclosure if applicable
High	Current HECVAT 4 workbook, 1EdTech TrustEd Apps self-assessment/certifications where available, ACR/VPAT, architecture/data-flow diagram, incident/BCP overview, AI provider/data-use documentation, pen-test or equivalent security evidence
Critical	Above plus detailed technical review, DPIA/PIA, AI impact assessment, threat model, integration sandbox test, legal review, executive risk acceptance, launch gates, periodic re-review

3. Normalize evidence

Vendor submitted artifact
→ evidence vault reference
→ framework/control mapping
→ evidence freshness check
→ reviewer assignment
→ finding/exception/remediation record
→ risk decision
→ contract/security addendum requirements
→ implementation/launch gates
→ periodic reassessment schedule

4. Decision states

Approved:
Controls and evidence meet risk requirements.

Approved with conditions:
Specific remediation, contract clause, configuration restriction,
or launch gate is required.

Pilot only:
Restricted data/function scope, synthetic data, no production integration,
time-limited evaluation.

Not approved:
Risk, evidence gap, product limitation, or contractual position is unacceptable.

Deferred:
Business case, data scope, or ownership is insufficiently defined.

5. Post-contract monitoring

```
Annual reassessment
Material-change notifications
Subprocessor change review
AI model/provider change review
Pen-test/assurance refresh
Accessibility ACR/VPAT refresh
Integration scope review
Incident/notification tracking
Renewal risk review
Offboarding/export verification
```

Vendor intake API

Request object

```
{
  "vendor_id": "ven_01J...",
  "product_name": "Semester Study Studio",
  "requesting_tenant_id": "inst_01J...",
  "business_owner": "student_success_office",
  "risk_tier": "high",
  "data_categories": [
    "education_record_pii",
    "course_content",
    "student_generated_content",
    "ai_prompt_output"
  ],
  "integrations": [
    "sso_saml",
    "lti_1_3",
    "oneroster"
  ],
  "ai": {
    "enabled": true,
    "providers": ["approved_provider_001"],
    "training_on_customer_data": false,
    "external_actions": false
  },
  "requested_go_live": "2027-01-15"
}
```

Evidence request rules

```
{
  "workflow": "high_risk_edtech_intake",
  "required_artifacts": [
    "hecvat_4_current_workbook",
    "trust_ed_apps_privacy_security_accessibility_self_assessment",
    "ai_data_use_and_provider_disclosure",
    "accessibility_acr_vpat",
    "data_flow_diagram",
    "subprocessor_list",
    "dpa",
    "incident_response_overview",
    "business_continuity_overview",
  ]
}
```

```

    "security_assessment_or_penetration_test_summary"
  ],
  "required_reviews": [
    "security",
    "privacy",
    "accessibility",
    "ai_governance",
    "integration_architecture",
    "legal_procurement"
  ],
  "launch_gates": [
    "approved_dpa",
    "approved_data_map",
    "approved_accessibility_review",
    "approved_ai_assessment",
    "integration_sandbox_validation"
  ]
}

```

Draft vendor-request email

Subject: Security, privacy, accessibility, interoperability, and AI review request — [Product Name]

Hello [Vendor Contact],

[Institution Name] is evaluating [Product Name] for [intended use and audience]. To complete our higher-education vendor review, please provide the current, accurate materials listed below.

Please do not include student, employee, customer, or other production personal data in your response. Secure-upload instructions are included below.

Requested materials

1. Current completed HECVAT 4 workbook in its original Excel format.
2. 1EdTech TrustEd Apps materials, if available:
 - Data Privacy Certification status or self-assessment
 - Security Practices self-assessment
 - Accessibility self-assessment
 - Generative AI Data self-assessment
 - Relevant interoperability certifications or conformance evidence
3. Current privacy policy, terms of service, DPA, and subprocessor list.
4. Architecture and data-flow diagram identifying hosting regions, subprocessors, integration points, encryption, tenant separation, and data-retention approach.
5. Current accessibility statement and ACR/VPAT, including known limitations and remediation plans.
6. Security overview, incident-response and business-continuity summaries, vulnerability-disclosure process, and current independent assessment or penetration-test executive summary, if available.
7. For any AI-enabled functionality:
 - AI feature inventory
 - Model/provider list and hosting location
 - Customer-data retention, training, and secondary-use terms
 - Source/grounding approach
 - User notice and opt-in/opt-out controls
 - Human-review and high-impact-decision boundaries
 - Evaluation, monitoring, and incident-response approach
8. Interoperability documentation for applicable standards and integrations, including LTI 1.3/LTI Advantage, OneRoster, QTI, SSO, SCIM, APIs, webhooks, data scopes, and offboarding/export procedures.

Please identify an appropriate security, privacy, accessibility, and AI-governance contact for follow-up questions.

Requested return date: [Date]

Secure submission location: [Secure portal]

Procurement contact: [Name, email]

Security review contact: [Name, email]

Thank you,

[Name]

[Title]

[Institution]

A completed HECVAT should be requested and returned in its official workbook format rather than converted to PDF, because its routing, applicability, and structured responses are intended to be used within the workbook.^[1]

AI governance rubric

Use this as an internal overlay across HECVAT, TrustEd Apps, NIST AI RMF, and Semester's product controls.

AI domain	HECVAT-oriented control	TrustEd Apps-oriented control	Semester requirement	Evidence
Inventory	Identify AI features, models, vendors, data, access, integrations	Disclose whether AI is used and its purpose	Model/system inventory by tenant, feature, provider, version, and risk tier	Inventory export, ownership record
Transparency	Document AI functionality, limitations, and customer impact	Inform users when AI is used	Source/Scope/Status UI; AI label; limitations; issue-report control	UI evidence, policy, usability tests
Data sources	Classify inputs, outputs, retrieval, and provider flow	Identify data sources and internal vs third-party AI	Tenant-scoped retrieval; source anchors; no cross-tenant retrieval	Data-flow diagram, retrieval tests
Training/secondary use	Govern provider training/retention and data sharing	Explain whether/how data is used with AI; user options	No general-model training on production customer/student data by default	Provider contract, technical configuration
User choice	Configure policy/consent and data sharing	Opt-in/out/user-preference options where applicable	Tenant/course/user controls; no forced AI use for core access	Settings/UI evidence
High-impact use	Prohibit/limit automated decisions; require oversight	Transparency and responsible data handling	No AI-only admissions, aid, discipline, accommodation, grading, or risk decisions	Policy, workflow test, authorization rules
Quality/validity	Test and monitor performance, bias, reliability	Data validity/bias considerations	Grounding, hallucination, fairness, accessibility, and evaluation thresholds	Eval plan/results, sign-off
Security/misuse	Threat-model prompt injection, tool abuse, exfiltration, provider changes	Disclose provider/data behavior	Input/output safeguards, least-privilege tools, kill switch, red-team tests	Threat model, test reports, incident runbook
Human escalation	Incident response, support, appeals, change control	User transparency and options	Human review, correction, appeal, feature disablement	Case workflow, incident drill

AI domain	HECVAT-oriented control	TrustEd Apps-oriented control	Semester requirement	Evidence
Retention/deletion	Define prompt/output/log lifecycle	Disclose data handling	Separate retention for prompts, outputs, retrieval caches, evaluation samples	Retention configuration, deletion test
Accessibility	Test AI output and AI controls for accessibility	Transparent, equitable access	Accessible AI UI, accessible generated content checks, alternative non-AI workflow	Accessibility test, issue tracker
Change management	Reassess model/provider/prompt/tool changes	Update disclosures when practice changes	Approval/retest workflow and customer change notice	Change record, release gate

Final operational model

Vendor intake
→ risk tier
→ required evidence request
→ HECVAT + 1EdTech + AI rubric mapping
→ security/privacy/accessibility/AI/integration review
→ findings, exceptions, and contractual controls
→ approval decision
→ pilot/integration launch gates
→ ongoing monitoring and renewal reassessment

This structure lets an institution evaluate Semester—or lets Semester evaluate its own suppliers—with enough rigor for security teams, enough specificity for accessibility and privacy teams, and enough transparency for academic and student-facing stakeholders.



1. <https://wolfia.com/hecvat>
2. <https://www.1edtech.org/1edtech-article/new-1edtech-rubrics-provide-valuable-insights-for-educators-selecting-trusted>
3. <https://www.1edtech.org/program/trustedapps>
4. <https://www.1edtech.org/standards/security-practices-rubric>
5. <https://www.1edtech.org/standards/data-privacy>
6. <https://er.educause.edu/articles/2025/2/hecvat-4-better-than-ever>
7. https://www.linkedin.com/posts/sid-naqvi_higher-education-community-vendor-assessment-activity-7406765950173138944-FRKY
8. https://www.1edtech.org/sites/default/files/media/docs/2024/WBR_Rubrics_032724.pdf
9. https://www.1edtech.org/sites/default/files/media/docs/2023/Data-Privacy_AI-Rubric.pdf
10. <https://trussed.ai/resources/1edtech-trusted-apps-rubric-for-ai-governance-guide>
11. <https://www.educause.edu/higher-education-community-vendor-assessment-toolkit>
12. <https://www.1edtech.org/standards/data-privacy/rubric>
13. <https://www.1edtech.org/standards/ai-rubric>
14. <https://www.educause.edu/higher-education-community-vendor-assessment-toolkit/hecvat-faqs-for-higher-education>
15. <https://www.1edtech.org/standards/accessibility-rubric>